

Information Security, Data Protection & Acceptable Use Policy

CATEGORY	Workplace & IT	EFFECTIVE DATE	January 1, 2026	REVIEW CYCLE	Annual / Q4
----------	----------------	----------------	-----------------	--------------	-------------

Article 1. Authentication, Password Governance & Multi-Factor Security

Information assets, customer data, and source code are the lifeblood of Nexus Corporation.
Credential compromise is the primary vector for enterprise intrusions; robust authentication hygiene is mandatory.

Credential Parameter	Corporate Security Requirement	Enforcement Rule
Minimum Password Length	At least 14 characters	Complexity filter: upper, lower, digit, symbol
Password Expiration Rotation	Every 90 calendar days	Automated expiration notice via Okta
Password History Retention	Cannot repeat previous 6 passwords	Enforced at directory level
Multi-Factor Authentication (MFA)	Hardware FIDO2 token or Okta Push	Mandatory on all SSO logins; SMS banned

- Passwords must be a minimum of 14 characters in length and include uppercase, lowercase, numbers, and special characters (!@#\$\$%^&*).
- Passwords must be changed every 90 days; reusing any of the previous 6 passwords is prohibited.
- MFA via company-approved hardware tokens (YubiKey) or authenticator apps is mandatory for all accounts.
- SMS-based 2FA is strictly prohibited across all internal and client-facing infrastructure due to SIM-swap vulnerabilities.

REGULATORY MANDATE & REQUIREMENT:
Password Sharing Prohibition: Sharing passwords or MFA push approvals with colleagues or supervisors is a severe disciplinary infraction.

Article 2. Workstation Security, Clean Desk Policy & Screen Locking

Physical security and workstation integrity are fundamental to safeguarding customer confidentiality. Employees must ensure sensitive screens and documents are never exposed to unauthorized visual inspection.

Security Action	Mandated Protocol	Operational Context
Workstation Screen Lock	Windows: Win+L macOS: Ctrl+Cmd+Q	Mandatory whenever stepping away from desk
Automated Idle Screen Lock	5 minutes inactivity timer	Enforced via central MDM profile
Physical Document Storage	Locked file cabinets / drawers	End-of-day clean desk compliance
Confidential Shredding	Locked cross-cut disposal bins	All physical printouts containing PII/financials

- Employees must lock their workstation screens whenever stepping away from their desk, in the office or in public.
- Clean Desk Policy: Sensitive physical documents, badges, and keys must not be left unattended on desks overnight.
- Whiteboards in conference rooms containing architecture diagrams or customer names must be erased after meetings.
- Visitors must be escorted at all times within secure corporate zones and must wear visible visitor badges.

REGULATORY MANDATE & REQUIREMENT:

Tailgating Prohibition: Never allow individuals without visible badges to follow you through secure badge-access doors.

Article 3. Removable Storage Devices & External Media Prohibition

External storage devices introduce severe vectors for malware propagation and intellectual property exfiltration. To prevent data leaks, our corporate workstations enforce strict hardware interface restrictions.

Peripheral Category	Usage Restriction	Authorized Alternative
Personal USB Thumb Drives	Strictly Prohibited (Port Disabled)	Corporate Google Drive Enterprise
External Hard Drives (Unencrypted)	Strictly Prohibited	Encrypted AWS S3 Buckets / Box Enterprise
Personal Peripheral Devices	Mouse/keyboard allowed; storage blocked	IT-provisioned hardware accessories

- Connecting unencrypted personal USB thumb drives, external hard disks, or unauthorized peripheral storage is prohibited.
- Exceptions require written authorization and hardware certification from the Chief Information Security Officer (CISO).
- All file transfers must utilize approved cloud repositories with end-to-end TLS 1.3 encryption and audit logging.

REGULATORY MANDATE & REQUIREMENT:

USB device insertion triggers an automated security alert to the Security Operations Center (SOC) for forensic review.

Article 4. Data Classification, Confidentiality & Customer Privacy

Data classification ensures that appropriate security controls are applied proportional to sensitivity.

All information created, transmitted, or stored on corporate infrastructure is categorized into four tiers.

Classification Tier	Data Examples	Handling & Encryption Rules
Public (Tier 1)	Marketing materials, job descriptions	No restrictions on external distribution
Internal (Tier 2)	Employee directory, general policies	Internal company access only; not for public release
Confidential (Tier 3)	Financial forecasts, roadmap docs	Restricted to authorized teams; encrypted at rest
Restricted / PII (Tier 4)	Customer PII, health records, secrets	Strict RBAC, KMS envelope encryption, audit logged

- Customer Personally Identifiable Information (PII) must never be stored on local laptop drives or unencrypted media.
- All databases containing Tier 4 data must utilize AES-256 encryption at rest and TLS 1.3 in transit.
- Employees must sign non-disclosure agreements (NDAs) covering proprietary technology and commercial secrets.

REGULATORY MANDATE & REQUIREMENT:

Using consumer AI tools (e.g., public ChatGPT) with proprietary code or customer data is strictly forbidden; use only internal enterprise AI Copilots.

Article 5. Security Incident Response, Phishing & Threat Reporting

Rapid incident reporting minimizes dwell time and limits lateral movement during sophisticated cyber attacks.

Every workforce member is an active sensory node in our defense-in-depth security perimeter.

Incident Severity	Definition & Example	Reporting SLA
P1 – Critical Incident	Ransomware, active breach of customer DB	Immediate notification within 1 hour
P2 – High Incident	Lost/stolen laptop, credential phishing	Notification within 2 hours
P3 – Medium / Low	Suspicious spam, policy non-compliance	Notification within 24 hours

- Suspected Phishing: Click the PhishAlarm button in Google Workspace immediately upon receiving suspicious email.
- Lost Devices: If a corporate laptop or smartphone is lost or stolen, report immediately to security-ops@nexus-corp.internal.
- Simulated Phishing Drills: Security conducts monthly phishing simulations; repeated failures require mandatory retraining.

REGULATORY MANDATE & REQUIREMENT:

No Retaliation for Reporting: Employees who accidentally click a malicious link and promptly report it will NOT face punitive discipline.

Article 6. Audit Logs, Monitoring, Compliance & Disciplinary Sanctions

Nexus Corporation maintains continuous audit trails across all digital endpoints and cloud tenants.
Employees should have no expectation of personal privacy when using corporate computers, networks, or accounts.

Monitored Asset	Audit Mechanism	Retention Period
Corporate Laptops & Desktops	EDR Telemetry & Process Logs	Retained for 365 days in SIEM (Splunk)
Corporate Network & VPN	NetFlow, DNS, and Proxy Logs	Retained for 180 days
Cloud Infrastructure (AWS/GCP)	CloudTrail & Access IAM Logs	Retained for 7 years for SOC2 / ISO27001

- All corporate laptop traffic, software installations, and file transfers are subject to automated security logging.
- Violations of security policy will result in progressive discipline up to and including termination of employment.
- Intentional data theft, selling secrets, or deploying malware will be prosecuted to the maximum extent of federal law.

REGULATORY MANDATE & REQUIREMENT:
Annual Security Recertification: All employees must complete the mandatory SOC2/ISO27001 Security Refresher by December 1st.